

AI SECURITY & GOVERNANCE COMPLIANCE ATTESTATION

PUBLIC VERIFICATION & ATTESTATION CHARTER

Google Genkit & Gemini Enterprise Integration

1. Executive Overview

This public attestation document certifies that KONTROLA has successfully engineered, integrated, and validated a state-of-the-art AI Security and Governance Shield across its financial intelligence, automation, and conversational models.

Financial management technologies that leverage generative Artificial Intelligence require strict oversight to safeguard customer assets and ensure continuous privacy. KONTROLA provides bank-tier security, ensuring that predictive cash flow modeling, automated categorization, and support interfaces are fully governed, mathematically bounded, and anonymized before external processing occurs.

2. Standardized AI Governance Frameworks

To maintain high integrity, KONTROLA's AI architecture was audited and designed in strict alignment with premier international AI security frameworks:

- **NIST AI Risk Management Framework (AI RMF 1.0):** Adopted the NIST core standards to Map, Measure, Manage, and Govern generative model activities.
This includes implementing continuous server-side flow validation, strict API monitoring, and comprehensive input checks.
- **OWASP Top 10 for LLM Applications:** Engineered dedicated defense mechanisms targeting specific OWASP vulnerabilities, primarily Prompt Injection (LLM01) and Sensitive Data Disclosure (LLM06).
- **Responsible AI Core Principles:** Ensured transparency through public AI disclosures, auditability via secure logging, and robustness via mathematical boundary verification.

3. Regulatory Compliance & Data Residency Standards

KONTROLA's AI systems comply fully with key national and international data privacy regulations, ensuring complete protection of user assets:

- **Ghana Data Protection Act, 2012 (Act 843):** Complies with strict West African data processing requirements. Generative AI operations are designed under the principle of data minimization—only the minimum required tokens are processed, and PII is scrubbed before leaving secure servers.
- **General Data Protection Regulation (GDPR):** Maintains global standard rights, including strict user consent boundaries, automated opt-out options, and absolute server-side token encryption during data transit.
- **Ghana Cybersecurity Act, 2020 (Act 1038):** Integrates security auditing, vulnerability checking, and access control policies for all algorithmic financial automation systems.

4. Specific Governance Guardrails Implemented

The governance security shield operates through four core automated modules that enforce safety boundaries server-side:

- **PII Scrubbing Engine:** A high-performance regex engine automatically intercepts ledger records, transaction narrations, and customer details, replacing email addresses, credit/debit card numbers, mobile phone numbers, and transactor names with standard anonymous tokens ([PHONE], [NAME]) prior to external AI processing. This guarantees zero leakage of private customer details.
- **Prompt Injection Shield:** Scans free-text fields in real time for system hijack indicators or malicious instructions. Attempts to bypass instruction bounds are intercepted server-side, raising a security alert and halting flow execution immediately.
- **Server-Side Mathematical Limits:** Critical savings suggestions (such as the "Safe-to-Save" co-pilot) undergo deterministic verification after AI generation. Recommendations are capped at 50% of the surplus balance, ensuring mathematical protection against overdrafts.
- **Enterprise Data Privacy Agreements:** Restricts LLM processing strictly to enterprise-tier APIs. Inputs are contractually isolated and are never retained, logged, or used by third parties to train future models.

5. Auditing, Verification & Verification Results

To certify execution integrity, the security shield was subjected to automated verification suites and compilation evaluations:

- **Vitest Security Verification Suite:**A dedicated test block executed multiple verification vectors, confirming that multiple Ghanaian phone formats, international card sequences, reference codes, and transactor name variations are successfully masked. It also validated prompt-hijacking interception blocks.
- **TypeScript Typecheck Compilation:**Validated zero compiler warnings and type safety across all core logic files (tsc compilation resolved with Code 0).
- **Production Next.js Build Package:** Verified that the integrated components compile and deploy cleanly under optimized production parameters.

6. Public Security & Governance Attestation

Based on our rigorous technical evaluation, continuous audits, and strict implementation of governance parameters, KONTROLA is officially certified as having successfully integrated its AI Security and Governance Shield.

We attest that KONTROLA's generative services meet elite levels of safety, user confidentiality, and regulatory compliance. User data remains locked, secure, and completely anonymous.

AUTHORIZED SECURITY COMMITTEE ATTESTATION

KONTROLA App Trust, Security, and Governance Division
Attestation Date: May 30, 2026
Status: APPROVED & DEPLOYED

SECURE & VERIFIED
NIST & OWASP COMPLIANT